# Penetration testing in web application

**Group: G-1**

**Ali Mohammed Balharith**

**Khalid Ali Alqarni**

**Hamed Mohammed Almuslem**

**Fouad Ahmed Alghamdi**

**Supervisor: Dr. Naif Almuslem**

**Second semester /2023-2024**

**Cyber Security Department**

| Contribution | |
|---|---|
| **Name** | **Percentage** |
| **ALI MOHAMMED BALHAITH** | **25%** |
| **Khalid Ali Alqarni** | **25%** |
| **Hamed Mohammed Almuslem** | **25%** |
| **Fouad Ahmed Alghamdi** | **25%** |

# Contents:

**Acknowledgment:** ..... 4

**Chapter 1: Introduction** ..... 5

**Project Overview:** ..... 6

**Problem Statement:** ..... 6

**Project Impact:** ..... 7

**Project Scope:** ..... 7

**AIMS and Objectives:** ..... 7

**Existing Solutions and Their Limitations:** ..... 8

**Chapter 2: Literature Review** ..... 9

**Background Section:** ..... 10

**Related Work Section:** ..... 11

**Chapter 3: Project Methodology** ..... 15

**Maintenance:** ..... 35

**Conclusion** ..... 36

**References** ..... 37

## Acknowledgment:

**In the Name of God, Most Gracious, Most Merciful I take a moment to express my deep gratitude and appreciation for the exceptional teamwork and dedication each and every one of you has shown during our group project. Together we have accomplished something truly remarkable, and I am extremely grateful for the opportunity to work with such a talented and committed group. I applaud the hard work, creativity, and professionalism each and every one of you brought to the project. Your contributions have been invaluable, and it is clear that everyone has invested their time and energy into producing high-quality work. Every assignment has been handled with diligence and commitment to excellence, which is truly commendable.**

**I am grateful for the trust and support that each of you placed in each other. Through this trust, we were able to delegate responsibilities, rely on each other's expertise, and achieve our goals collectively. I learned so much from each team member, and I am grateful for the opportunity to grow both professionally and personally through this collaborative experience.**

**As we conclude this project, on behalf of our group, we thank Dr. Naif Al-Musallam for his great effort in our distinguished journey in this project**

**I would like to extend my heartfelt gratitude to our parents and families. We are grateful for your continuous support and unparalleled encouragement. You have been a true source of strength for us throughout this project and in every endeavor we undertake. We appreciate your understanding and ongoing encouragement, as you are fundamental pillars of our success. Thank you for the trust and support you provide us; we are indebted to you in every sense of the word.**

# Chapter 1: Introduction

## Project Overview:

**Web security is just not a thing you can actually ignore. Everyone makes applications and websites and on the other hand the consumers want to enjoy the features, but they care about their privacy and don't want their private or sensitive information to go in wrong hands. Sensitive information may contain their email, passwords or some bank related information that can really turn their worlds upside down. Sensitive information can be easily compromised if not properly managed.**

**Web penetration and application testing is a necessary procedure that every website or application must go through in order to ensure the privacy of their end customers. Web penetration and testing have some methods that check the sites or applications for vulnerabilities that can be exploited by someone who knows the hooks and crooks of how to steal information. [6]**

## Problem Statement:

| | |
|---|---|
| **What is problem?** | **The presence of security vulnerabilities in the company's website that leads to the theft of the database and the embezzlement of the company's assets.** |
| **Why there is a problem?** | **1- SQL Injection**<br>**2- Cross Site Scripting (XSS)**<br>**3- Business Logic Error**<br>**4- Upload Vulnerabilities**<br>**5- Broken Authentication** |
| **How are you going to address the problem?** | **1- By implementing security solutions, discovering the vulnerability, and dealing with it professionally.**<br>**2- Expected result and its significance**<br>**3- Ensuring the workflow of the site and not exploiting vulnerabilities. [7]** |

## Project Impact:

**Maintaining information security from theft or exploitation by attackers.**

## Project Scope:

**The scope of the project includes defining the target systems, conducting reconnaissance, performing a comprehensive vulnerability assessment, exploiting identified vulnerabilities, escalating privileges, simulating data mining attempts, and providing recommendations for mitigating the identified vulnerabilities. The project primarily focuses on web applications and common vulnerabilities such as SQL injection, cross-site scripting (XSS), business logic errors, upload vulnerabilities, and broken authentication.**

**"The project does not include website and network development or digital forensic examination."**

### AIMS AND OBJECTIVES:

**Here are the aims and objectives of the project, arranged in points:**

**1.Evaluate IT infrastructure security: Conduct penetration testing to assess the security of the IT infrastructure. Safely expose vulnerabilities and weaknesses to understand the level of protection in place.**

**2.Assess defense mechanisms: Evaluate the efficiency of existing defense mechanisms, including tools and policies, in detecting and preventing security threats. Identify any gaps or areas for improvement.**

**3.Identify risks: Regularly conduct penetration testing to identify current and potential risks to the IT infrastructure. This helps in understanding the threat landscape and enables proactive risk management.**

**4.Manage risks: Use the findings from penetration testing to develop strategies and measures for managing identified risks. Implement appropriate security controls and practices to mitigate vulnerabilities.**

**5.Achieve higher security standards: Continuously improve the security posture of the IT infrastructure by addressing vulnerabilities and enhancing defense mechanisms. Regular penetration testing helps in achieving and maintaining higher security standards.**

**6.Stay updated with emerging threats: Keep pace with rapidly evolving security threats by conducting regular penetration testing. This helps in identifying and addressing new vulnerabilities introduced by technological advances.**

**7.Compliance with regulations: Ensure compliance with relevant security standards, legal requirements, and industry regulations through penetration testing. Identify any gaps in compliance and take corrective actions.**

**8.Enhance security awareness: Use the results of penetration testing to raise security awareness among stakeholders. Educate employees about vulnerabilities, risks, and best practices for maintaining a secure IT environment.**

**9.Continual improvement: Use the insights gained from penetration testing to drive continual improvement in security measures. Regularly reassess the IT infrastructure to adapt to changing threats and maintain an effective security posture. [2]**

## Existing Solutions and Their Limitations:

**This section discusses the existing work that is related to penetration testing for companies.**

## 1- Tamkeen Company:

**Tamkeen Security Company is a company specialized in governance, risk and compliance (GRC) services in the Kingdom of Saudi Arabia and provides its products and services to the public and private sectors. [1]**

**Strengths:**

**Individuals can benefit from the service.**

**Limitation:**

**Serves the business sector only (does not serve individuals)**

## 2- Sadeed Company:

**Sadeed Cybersecurity Company is a national company specialized in providing cyber solutions to measure and achieve compliance with cybersecurity standards and frameworks, in addition to providing advisory services in the field of cybersecurity to the business sector and individuals.**

**Strengths:**

**Our prices are very reasonable for the services we provide.**

**Limitation:**

**They charge high fees for services**

## Solve the problem.

**Our project will overcome the limitations of current work by conducting comprehensive penetration testing that serves companies and individuals alike, as well as on a global level, and the cost will be reasonable compared to the rest of the existing companies.**

# Chapter 2: Literature Review

**In the previous chapter, we presented our proposed project, penetration testing for Al-Ahsa Financial Company, and in this chapter we will discuss existing companies that solve the problem of penetration testing and scanning security vulnerabilities.**

**The company needs to ensure that the data is secured and protected from hacking, so we will do the following:**

1- **SQL Injection**
2- **Cross Site Scripting (XSS)**
3- **Business Logic Error**
4- **Upload Vulnerabilities**
5- **Broken Authentication**

**CTC (Cyber Technology Company) is considered one of the famous companies in the field of cybersecurity solutions. The company has a robust cybersecurity system for premium customer data.**

**CTC provides security solutions to Al-Ahsa Finance Company. It is considered one of the major companies in the field of financial services. The company provides online banking services and handles customers' sensitive financial information. Cybersecurity is one of the company's main priorities, and the company seeks to implement strong security measures to protect data. But the company in general emphasizes the need to test the system periodically to identify potential vulnerabilities and enhance cybersecurity, so the company decided to conduct a penetration test to ensure the robustness of the system and its ability to resist cyberattacks.**

## Background Section:

**We will first start by defining the terms used in this project for clarity:**

| Term | Identification |
|---|---|
| Penetration testing | a security exercise where a cyber-security expert attempts to find and exploit vulnerabilities in a computer system [14] |
| SQL | Structured query language (SQL) is a programming language for storing and processing information.[25] |

| | |
|---|---|
| **SQL Injection** | **A common attack vector that uses malicious SQL code for backend database manipulation to access information that was not intended to be displayed.[25]** |
| **XSS** | **Cross-site scripting (XSS) is a type of vulnerability that allows an attacker to execute malicious scripts on the victim's web browser resulting in various side effects such as data breach, theft of cookies, passwords, credit card numbers, etc. [15]** |
| **Upload Vulnerabilities** | **Upload vulnerabilities refer to security weaknesses or flaws in web applications that allow unauthorized or malicious file uploads. These vulnerabilities can be exploited by attackers to upload and execute unauthorized files, such as malicious scripts or malware, onto a target system.[13]** |
| **Business Logic Error** | **We define as "Application Logic Vulnerability" (hereafter "Logic Vulnerability", "LV"), the flaw present in the faulty implementation of the business logic within the application code.** |
| **Broken Authentication** | **Broken Authentication is a kind of web vulnerability which occurs due to the misconfiguration of session management [20]** |

# Related Work Section:

## 1- Tamkeen Company

**Tamkeen Security Company is a company specialized in governance, risk and compliance (GRC) services in the Kingdom of Saudi Arabia and provides its products and services to the public and private sectors. [9]**

**Strengths:**

**Individuals can benefit from the service.**

**Limitation:**

**Serves the business sector only (does not serve individuals)**

## 2- Sadeed Company

**Sadeed Cybersecurity Company is a national company specialized in providing cyber solutions to measure and achieve compliance with cybersecurity standards and frameworks, in addition to providing advisory services in the field of cybersecurity to the business sector and individuals. [10]**

**Strengths:**

**Our prices are very reasonable for the services we provide.**

**Limitation:**

**They charge high fees for services**

## 3- Technology Control Company (TCC):

**TCC is a specialized company in the fields of security services, digital services and big data. TCC has been offering state-of-the-art solutions based on leading industry methodologies and frameworks. [21]**

**Strengths:**

**We provide the service by manual inspection in order to ensure the accuracy of the inspection**

**Differences between automated scanning and manual scanning with respect to discovering vulnerabilities:**

**Practical implications: Manual effort is important to complete automated scanning in order to obtain satisfactory accuracy regarding network security issues [17].**

**Limitation: They do not deal with manual inspection.**

## 4- Salam Company:

**A leading telecom provider offering next-generation ICT solutions for broadband, connectivity, cloud computing, managed services, security services, satellite services, and internet services for government, businesses, wholesale, and consumer sectors.**

**Strengths:**

**While providing the vulnerability scanning service, we are keen to provide a course to the organization's employees on how to use technical systems and practices correctly.**

**Limitation:**

**They do not have a service to train employees to use security methods when using the systems**

## 5- Saudi Cybersecurity Company:

**Empowering companies to counter cyber threats and implement cyber security measures via AI technology through hands-on monitoring and identification of potential threats through proven ethical hacking services and assistance. [23]**

**Strengths:**

**We provide the service through manual inspection to ensure the accuracy of the inspection.**

**Limitation:**

**When implementing the service, they rely on artificial intelligence technology, and this may be less accurate than manual inspection, as we mentioned previously with Saeed Company. [17]**

1- **SQL injection:**

**SQL injection is a type of security vulnerability that occurs in database-driven web applications where an attacker injects malicious code into the application to gain unauthorized access to sensitive information. This paper aims to provide a comprehensive and systematic review of the existing methods for preventing and detecting SQL injection attacks.**

**Prevent Technique:**

**SQL injection attacks can be prevented through the implementation of several techniques that ensure the proper validation of user-supplied data and secure processing of SQL statements.**

A. **Input Validation: Input validation is a crucial step in preventing SQL injection attacks. It involves validating user-supplied data to ensure that it meets certain constraints before being processed by the application.**
B. **Parameterized Queries: Parameterized queries are a secure method for executing SQL statements by specifying the parameters separately from the main SQL query. This method eliminates the possibility of an SQL injection attack by preventing the attacker from injecting malicious code into the query. The parameters are passed to the query as separate values, rather than being included as part of the SQL statement, making it impossible for the attacker to inject malicious.[11]**

**2- Cross-Site Scripting (XSS)**

**Cross-Site Scripting (XSS) attack is the top most vulnerability found in today's web applications which to be a plague for the modern web applications. XSS attacks permit an attacker to execute the malicious scripts on the victim's web browser resulting in various side-effects such as data compromise, stealing of cookies, passwords, credit card numbers etc. [12]**

**Upload vulnerabilities:**

**Upload vulnerabilities refer to security weaknesses or flaws in web applications that allow unauthorized or malicious file uploads. These vulnerabilities can be exploited by attackers to upload and execute unauthorized files, such as malicious scripts or malware, onto a target system. [13]**

**3- Business Logic Error:**

**ACCESS CONTROL MODEL:**

**Access control model for dynamically generated client-side content. The proposed model turns the traditional client/server access control model on its head and addresses how to protect the sensitive content that clients disclose to servers. Since client content is dynamically generated, the usual approach of associating a policy with the resource a priori does not work. The model has provisions for determining the sensitivity of dynamic client content, mapping the content to an access control policy, and establishing the trustworthiness of the server before disclosing the content to the server [18]**

**4- Broken Authentication:**

- **Session Misconfiguration Attack:**

  **Session duration is one of the major facts in maintaining a secure Authentication process of web applications. As soon as the user credential is validated from a system, it assigns a session for the particular user with a session ID for a limited period of time. In case the developer of the web application sets the session duration parameter with a large value, the session will remain active for that specific period if the user not logged off their account as directed by the designer of the application. Therefore, that session can be reestablished to re-using by an intruder which leads to Broken Authentication add-ons for bypassing admin panel in session misconfiguration exploitation process. [19]**

# Chapter 3: Project Methodology

**In this chapter, we will cover the common methodology used in managing SATESE penetration testing projects. This methodology consists of six main phases that guide the penetration testing process in a systematic and organized manner [planning, analysis, design, implementation, testing and maintenance]. We will review these stages in detail:**

| | |
|---|---|
| **Planning** | **In this stage, the objectives of the penetration test and the associated scope of work are defined. The required resources are identified and a timetable is set for implementing the various activities. This stage also includes defining standards and laws related to testing and obtaining** |
| **Analysis** | **In this stage, the target system is analyzed and potential vulnerabilities are identified. This includes assessing the system infrastructure and analyzing potential vulnerabilities in the configurations and software** |
| **Design** | **In this phase, a detailed test plan is designed and implemented. This plan should include defining specific goals and strategies for each phase of testing. The tools and techniques used in testing are also identified.** |
| **Implementing** | **In this phase, the test plan designed in the previous phase is executed. Attacks are carried out, potential vulnerabilities are tested, and relevant data is collected.** |
| **Testing** | **In this phase, the results collected from the implementation phase are analyzed and evaluated. The discovered vulnerabilities are verified, classified and prioritized. A report is also provided including all required findings and recommendations.** |
| **Maintenance** | **In this phase, continuous support is provided to the tested system and the required recommendations are applied to fix the discovered security vulnerabilities. Necessary security updates are also being made and security policies and safeguards have been enhanced.** |

**Figure 1 Project Methodology Planning**

## Project planning:

**We will follow a set of plans to maximize our input and deliver the best to our clients.**

**Here are the main points:**

**Objectives:**

**•Determine the scope of work in the company and obtain approvals from it.**

**•Providing the best solutions at a relatively low cost.**

**•Submit a final and detailed report to the company detailing the work we have carried out.**

**During this stage:**

**• Develop and implement a project plan to enhance the security framework of the financial institution through.**

**Implement vulnerability detection, database scanning and comprehensive site analysis to protect customer data and assets**

**Effective way.**

**• This plan will include a comprehensive analysis, design and implementation of the security architecture**

**Components, testing their functions, and developing a maintenance strategy to ensure their continuity**

**Protection and compliance.**

**Timetable for the project:**

**Below is the project timeline we followed to deliver the project.**

| Project Timelines | | | | | | | | | | | | |
|---|---|---|---|---|---|---|---|---|---|---|---|---|
| Event | Weak 1 | Weak 2 | Weak 3 | Weak 4 | Weak 5 | Weak 6 | Weak 7 | Weak 8 | Weak 9 | Weak 10 | Weak 11 | Weak 12 |
| Project-Baring Storming | | | | | | | | | | | | |
| Project-Proposal | | | | | | | | | | | | |
| Ch.1- Introduction | | | | | | | | | | | | |
| Ch.2- Literature Review | | | | | | | | | | | | |
| Ch.3- Methodology | | | | | Final Report | | | | | | | |
| Ch.4- Conclusion | | | | | | | | | | | | |
| Ch.5- Reference | | | | | | | | | | | | |

# Analysis:

**At this stage we will define the requirements necessary to complete the setup process in accordance with the agreement between us and the company.**

**Functional requirements:**

| item | Description | Quantity |
|---|---|---|
| LAPTOP | user | 1 |
| Server side | Means ex:(PHP) | 1 |
| Client side | Means (user) | 1 |

**Non-Functional requirements:**

| item | Description | Quantity |
|---|---|---|
| Burp Suite | Performing security testing of web applications | 1 |
| Kali Linux | Operating system | 1 |
| SQLMAP | Tool use for Injection | 1 |
| Training | A training course to provide the necessary information and enhance security awareness. | |

## Design:

**At this stage, the penetration testing plan is designed on 5 levels as follows:**

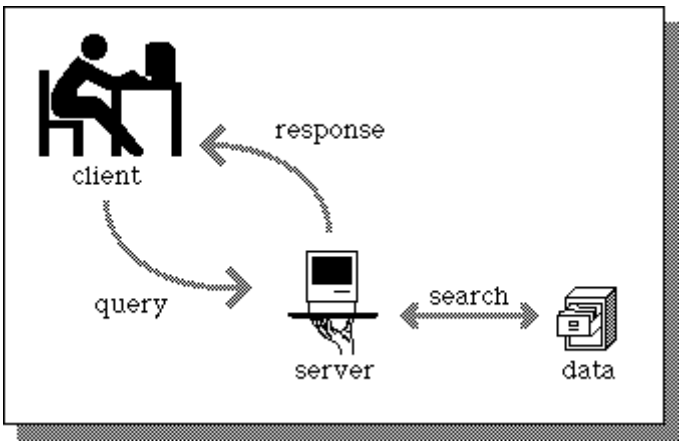


**Figure 3 Project Methodology Design [24]**

## Implementing:

**Start implementing the service with a description of the implemented service.**

## SQL injection process:

First: We will manually ensure SQL injection protection using the quote ['] mark.

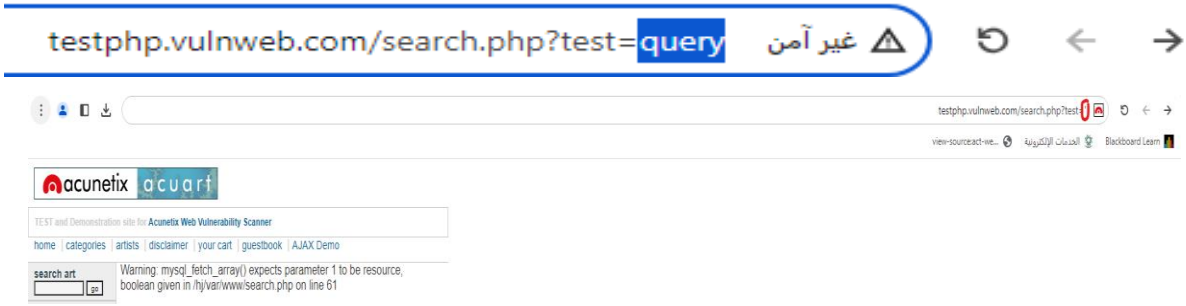


**Figure 4 Project Methodology Design**

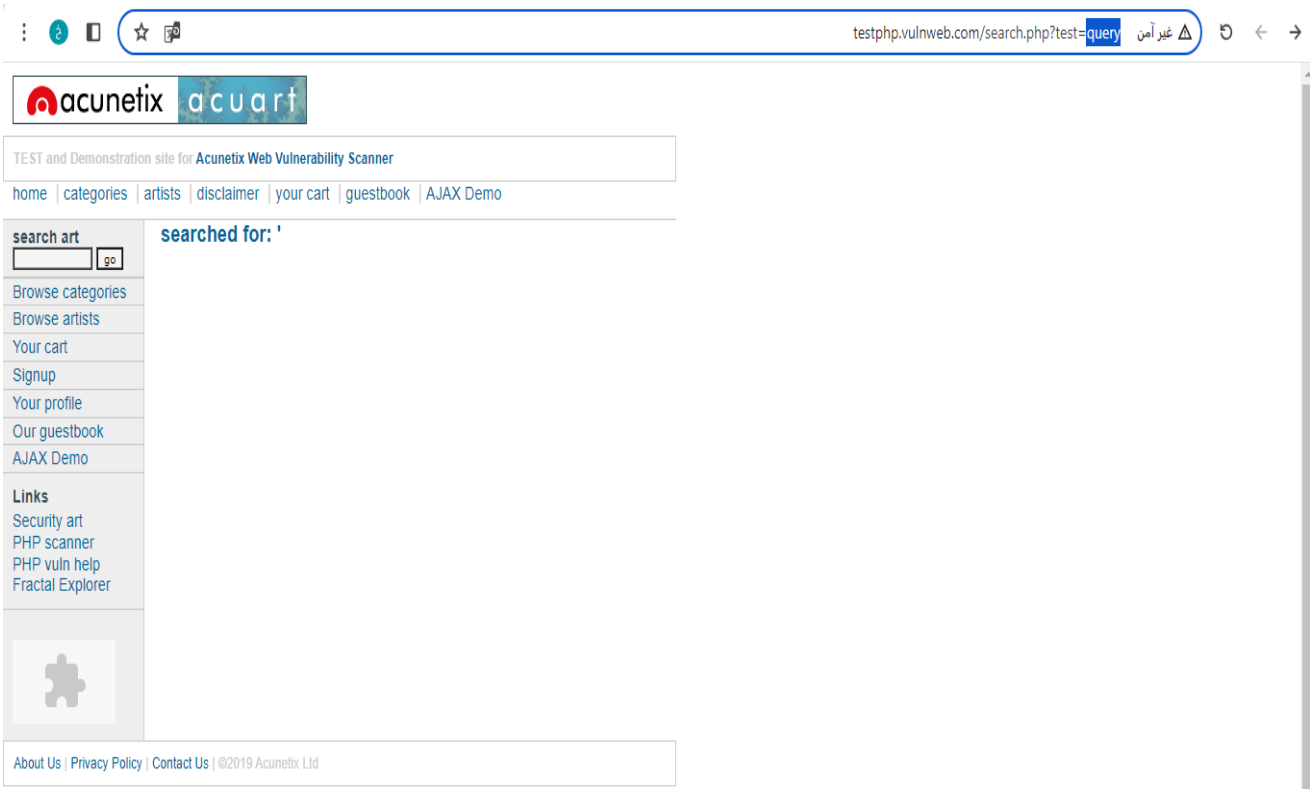


**Figure 5 Project Methodology Design**

**Secondly, after ensuring that the site can be injected, we use the sqlmap tool to extract the database names**

```
┌──(kali㉿kali)-[~]
└─$ sqlmap -u http://testphp.vulnweb.com/artists.php?artist=1 --random-agent --dbs
```

```
kali@kali: ~
File  Actions  Edit  View  Help
[10:13:43] [INFO] testing 'MySQL ≥ 5.0.12 OR time-based blind (query SLEEP)'
[10:13:49] [INFO] testing 'MySQL ≥ 5.0.12 AND time-based blind (SLEEP)'
[10:13:54] [INFO] testing 'MySQL ≥ 5.0.12 OR time-based blind (SLEEP)'
[10:14:18] [INFO] GET parameter 'artist' appears to be 'MySQL ≥ 5.0.12 OR time-based blind (SLEEP)' injectable
[10:14:18] [INFO] testing 'Generic UNION query (NULL) - 1 to 20 columns'
[10:14:18] [INFO] automatically extending ranges for UNION query injection technique tests as there is at least one other
 (potential) technique found
[10:14:21] [INFO] 'ORDER BY' technique appears to be usable. This should reduce the time needed to find the right number
of query columns. Automatically extending the range for current UNION query injection technique test
[10:14:24] [INFO] target URL appears to have 3 columns in query
[10:14:32] [INFO] GET parameter 'artist' is 'Generic UNION query (NULL) - 1 to 20 columns' injectable
GET parameter 'artist' is vulnerable. Do you want to keep testing the others (if any)? [y/N] n
sqlmap identified the following injection point(s) with a total of 61 HTTP(s) requests:
---
Parameter: artist (GET)
    Type: boolean-based blind
    Title: AND boolean-based blind - WHERE or HAVING clause
    Payload: artist=1 AND 4591=4591

    Type: time-based blind
    Title: MySQL ≥ 5.0.12 OR time-based blind (SLEEP)
    Payload: artist=1 OR SLEEP(5)

    Type: UNION query
    Title: Generic UNION query (NULL) - 3 columns
    Payload: artist=-6288 UNION ALL SELECT CONCAT(0x71626a7671,0x4851486f4b646b716670456445 4f6342667952544144624f66706a62
74634c6c49595a474b557a67,0x7176717a71),NULL,NULL-- -
---
[10:14:49] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: PHP 5.6.40, Nginx 1.19.0
back-end DBMS: MySQL ≥ 5.0.12
[10:14:53] [INFO] fetching database names
available databases [2]:
[*] acuart
[*] information_schema

[10:14:53] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/testphp.vulnweb.com'
[10:14:53] [WARNING] your sqlmap version is outdated

[*] ending @ 10:14:53 /2024-01-21/

┌──(kali㉿kali)-[~]
└─$
```

Figure 6 Project Methodology Design

# Cross Site Scripting (XSS) process:

## Reflected XSS:

### First in Search bar Input Script Code

Figure 7 Project Methodology Design

### Then will be see the script is executed

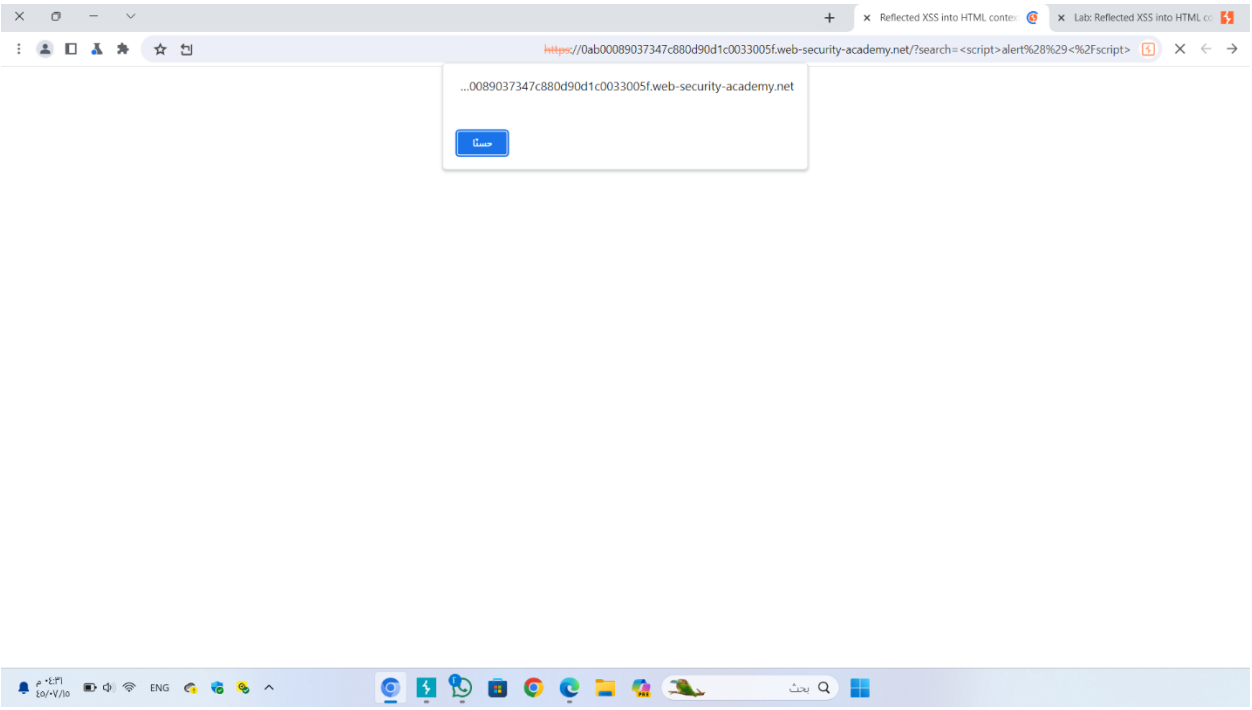


Figure 8 Project Methodology Design

## Stored XSS:

**We should leave a comment to save in Database**

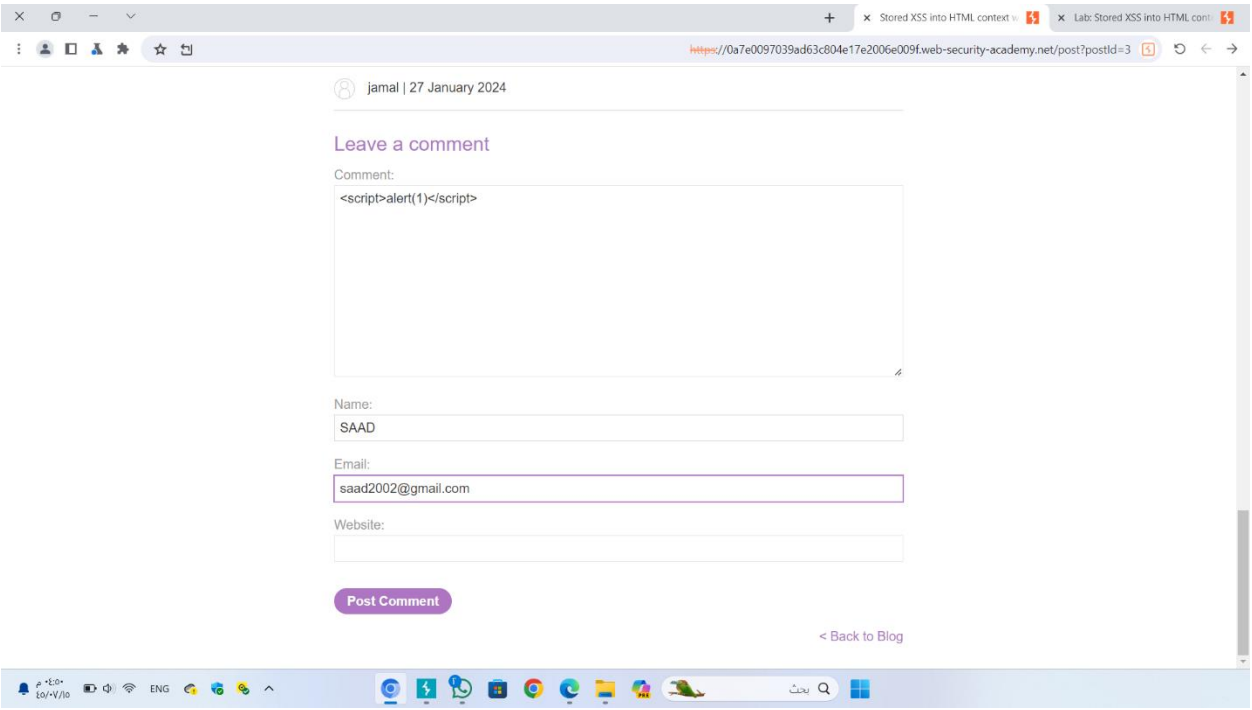


**Figure 9 Project Methodology Design**

## Here I inject Script code to save in Database (<script>alert()</script>)

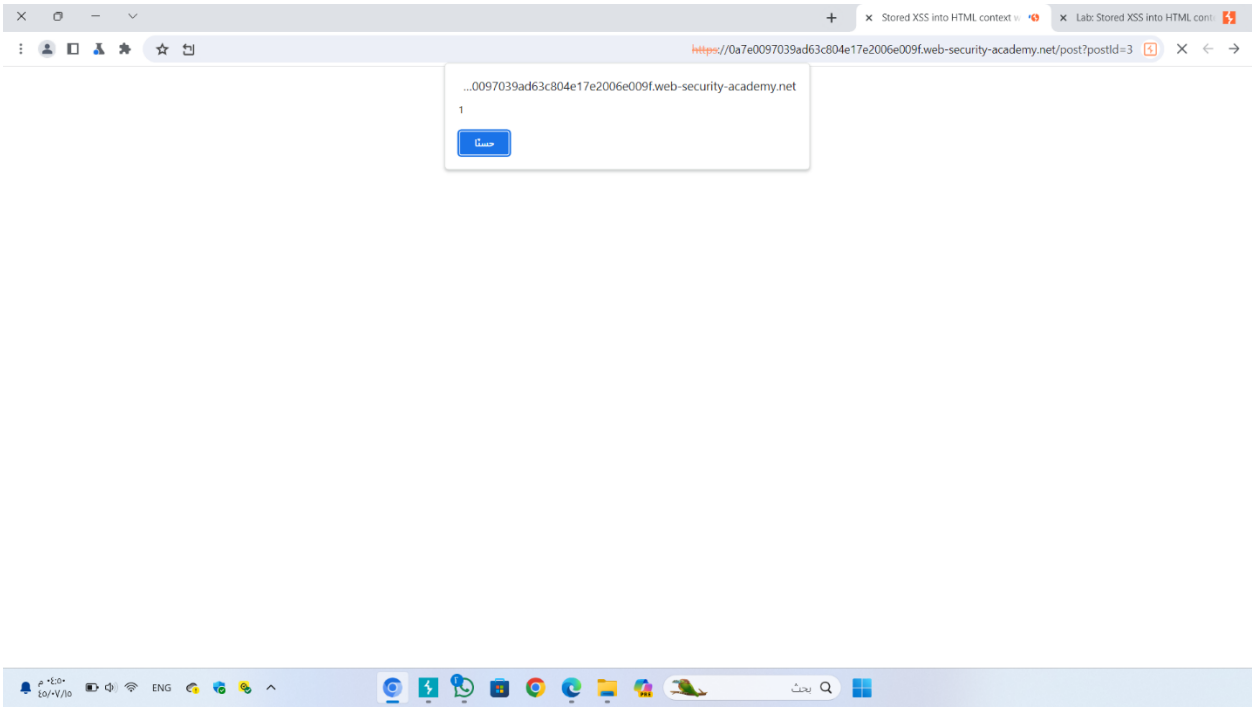


**Figure 10 Project Methodology Design**

### Here we see the code is save in Database and is executed

# Upload Vulnerabilities process:

### First sign into your account

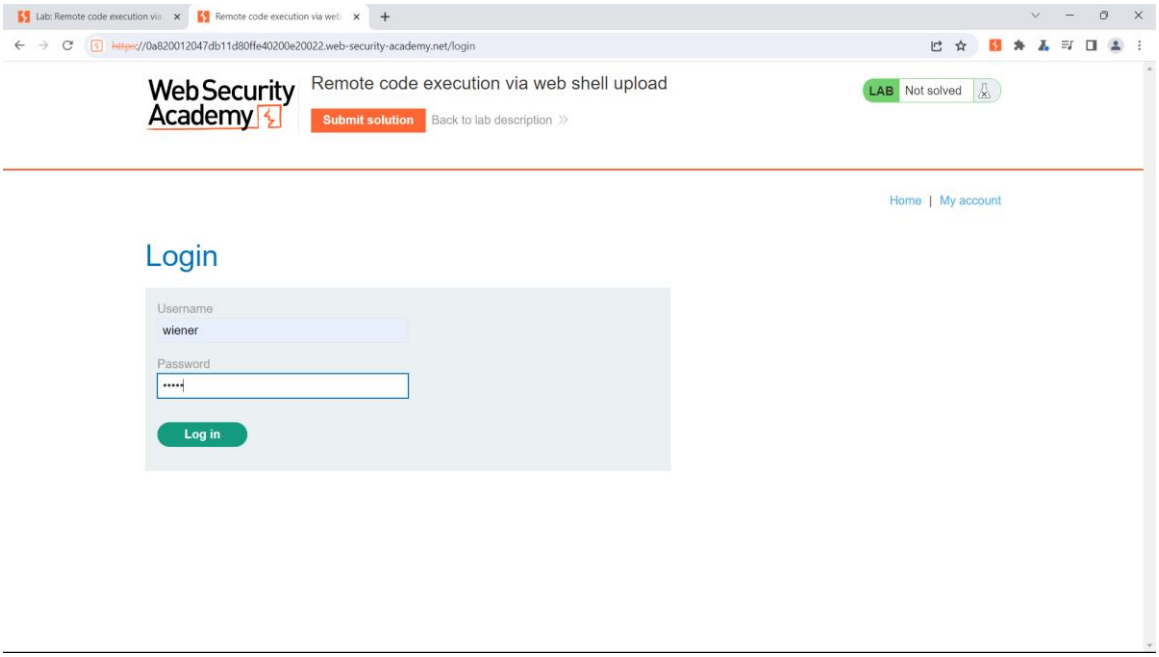

Figure 11 Project Methodology Design

## Second go to your account and upload avatar then choose a simple code php to executed

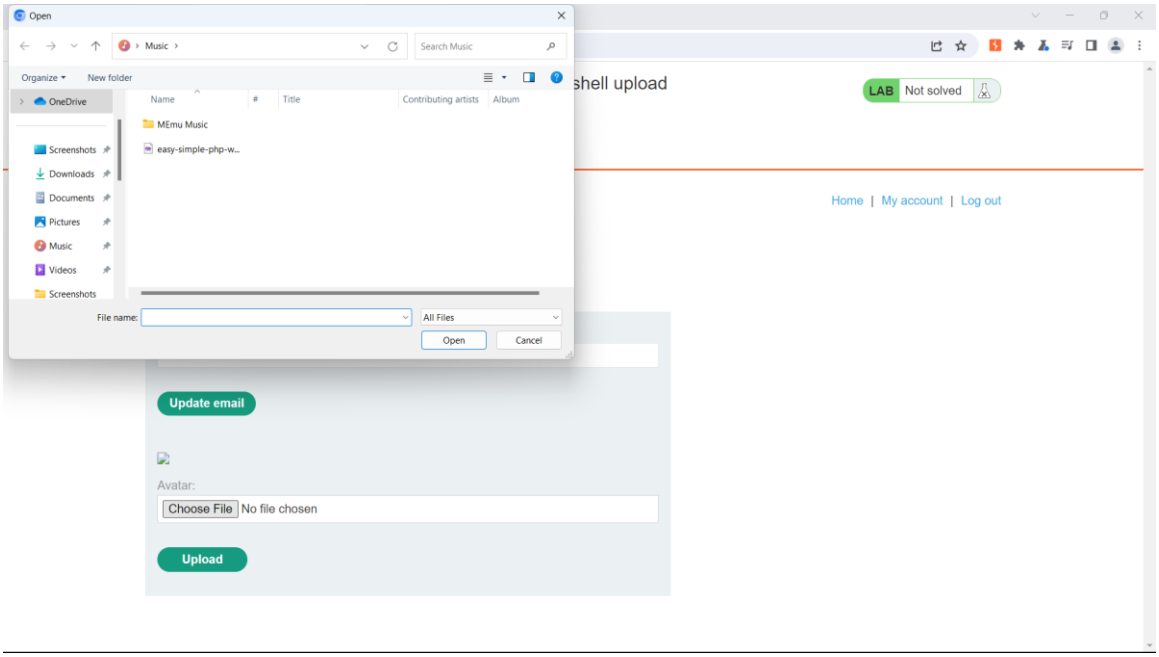


Figure 12 Project Methodology Design

## Now you will be see the password

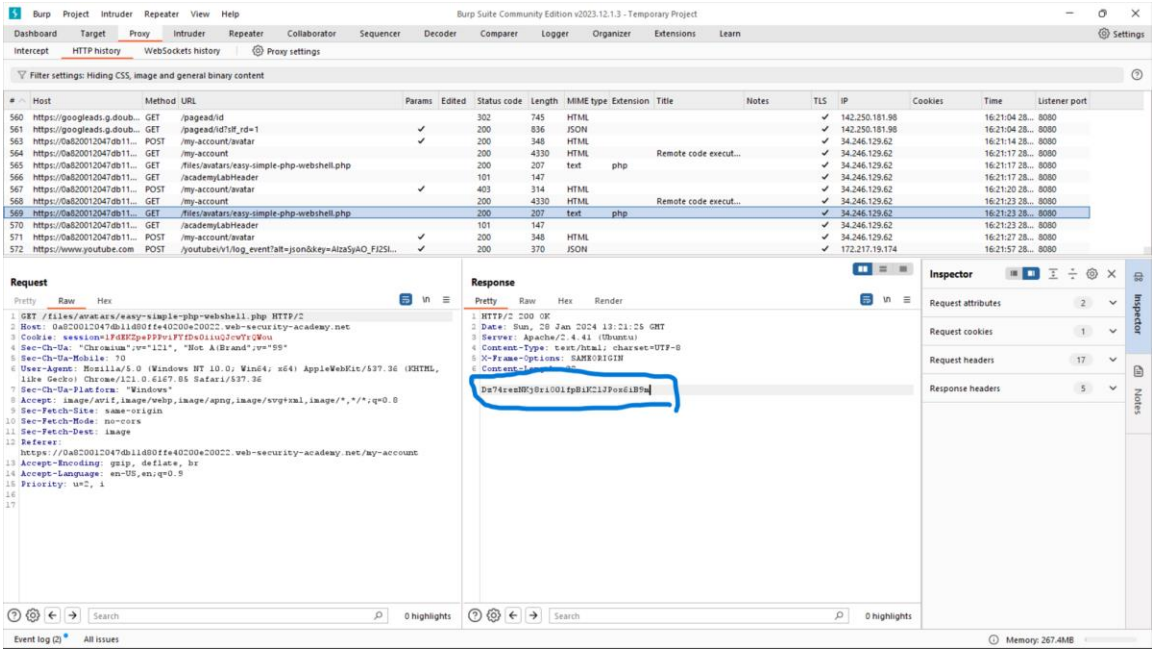


Figure 13 Project Methodology Design

**Copy the password and paste in the answer**

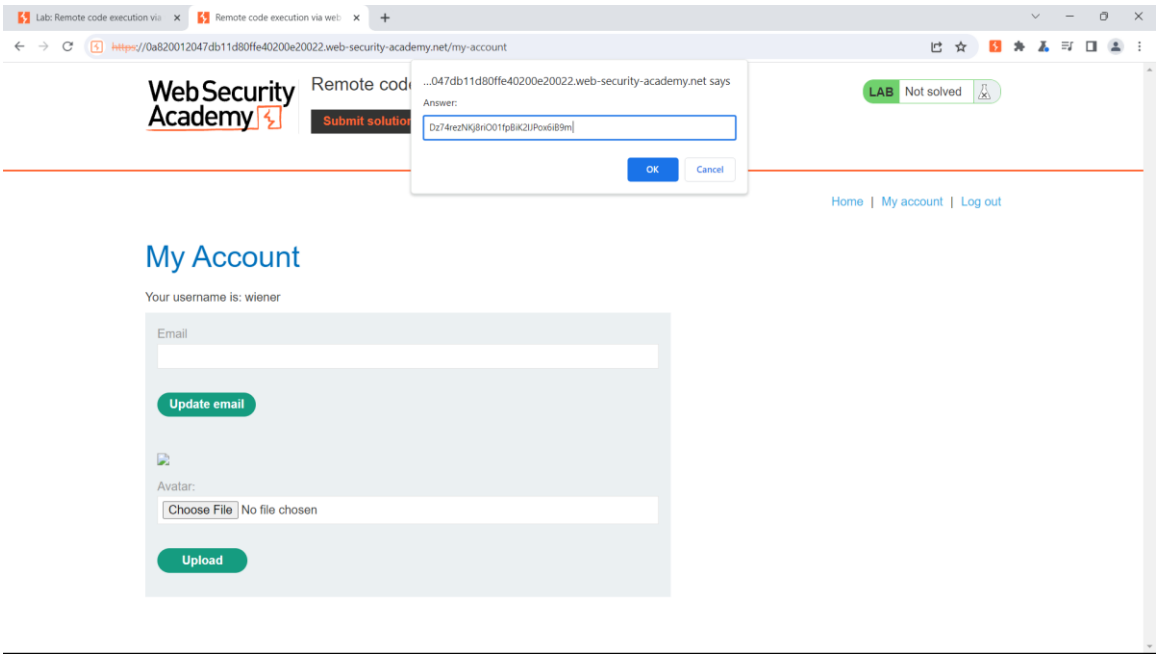


**Figure 14 Project Methodology Design**

**ss**

# Broken Authentication process:

**In this Lab explain how to broken authentication in accounts**

**First, I want to take account over Carlos and My account is Wiener:**

## Log in to Weiner

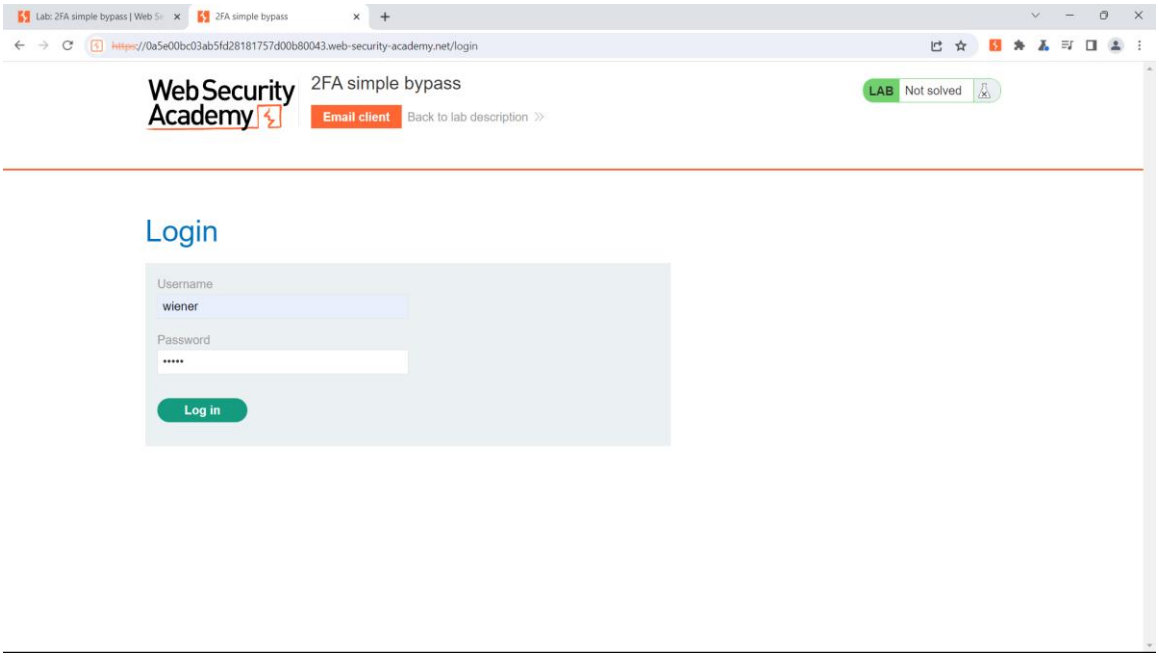


**Figure 15 Project Methodology Design**

## Secondly, I received OTP password I put it

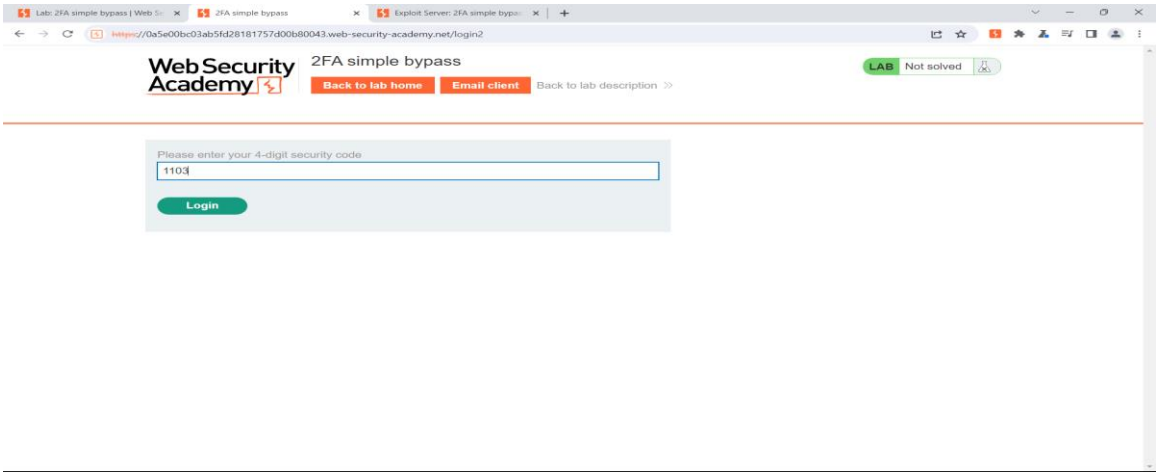


**Figure 16 Project Methodology Design**

## Now I already login it, copy URL

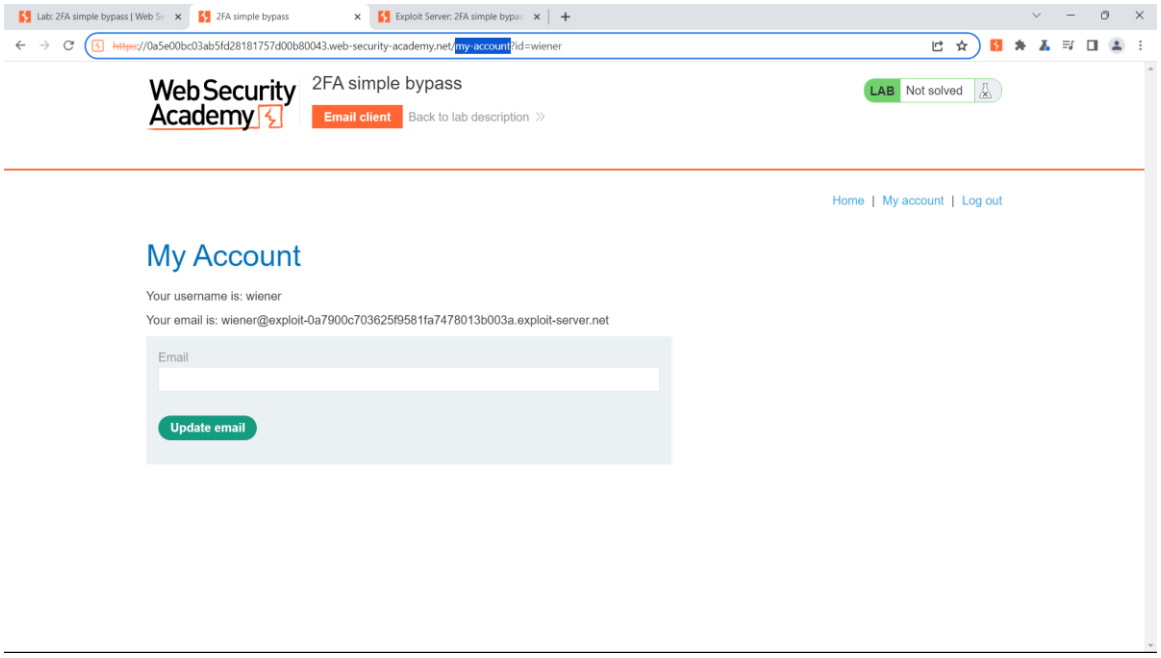


**Figure 17 Project Methodology Design**

## Then log out from Wiener, Now login to Carlos

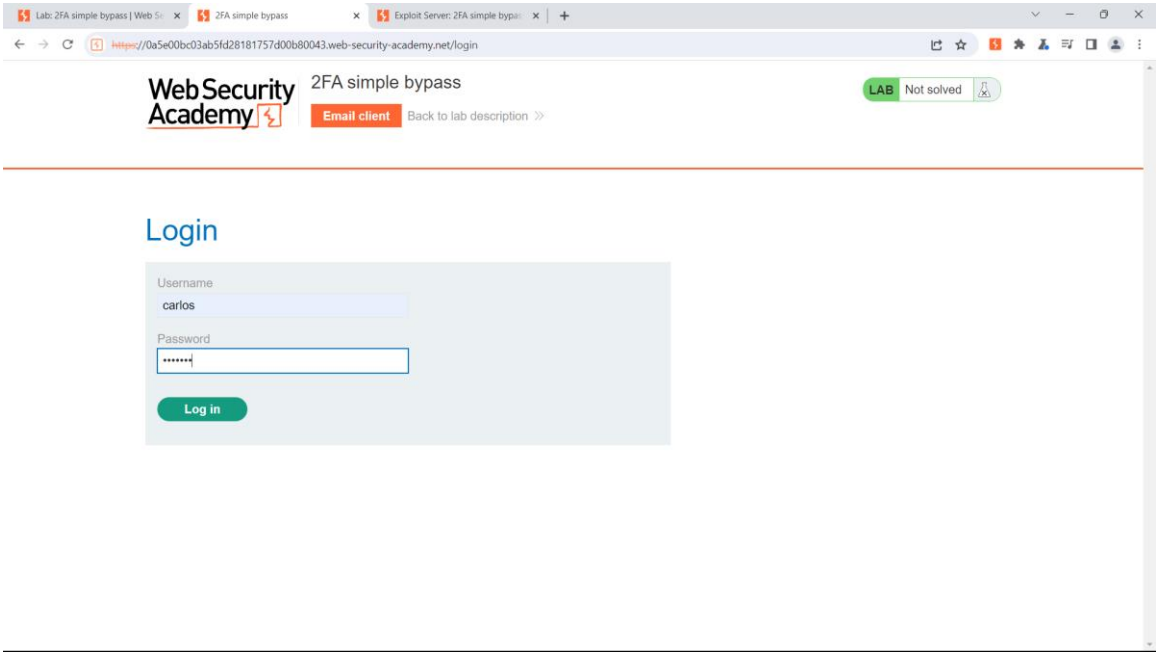


**Figure 18 Project Methodology Design**

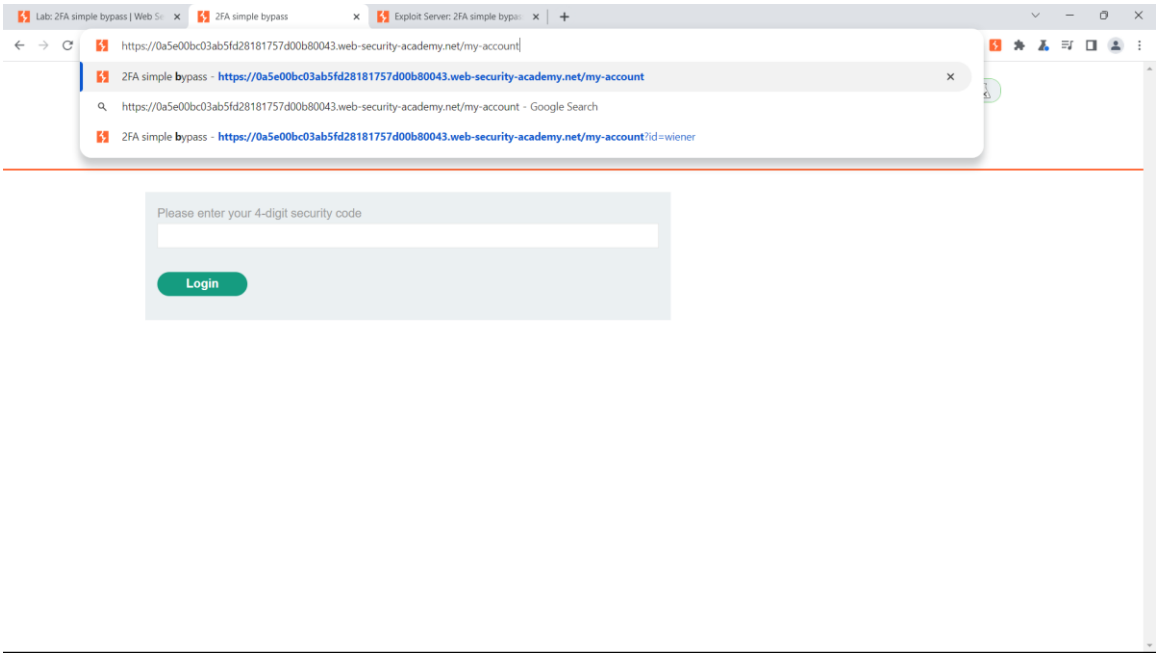


**Figure 19 Project Methodology Design**

## Here change URL and here will be bypass 2FA

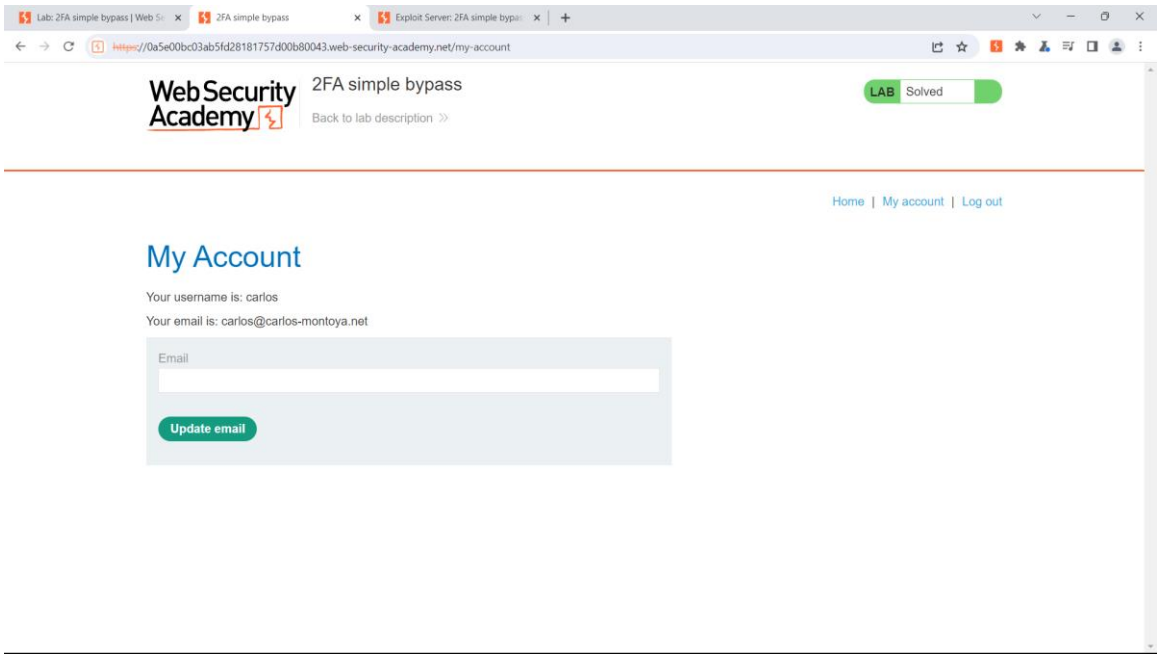


**Figure 20 Project Methodology Design**

## Finally, I access to account Carlos without OTP Authentication

# Business Logic Error:

**This explains one of the business logic vulnerabilities, which is the ability to purchase a product with an amount greater than what is available.**

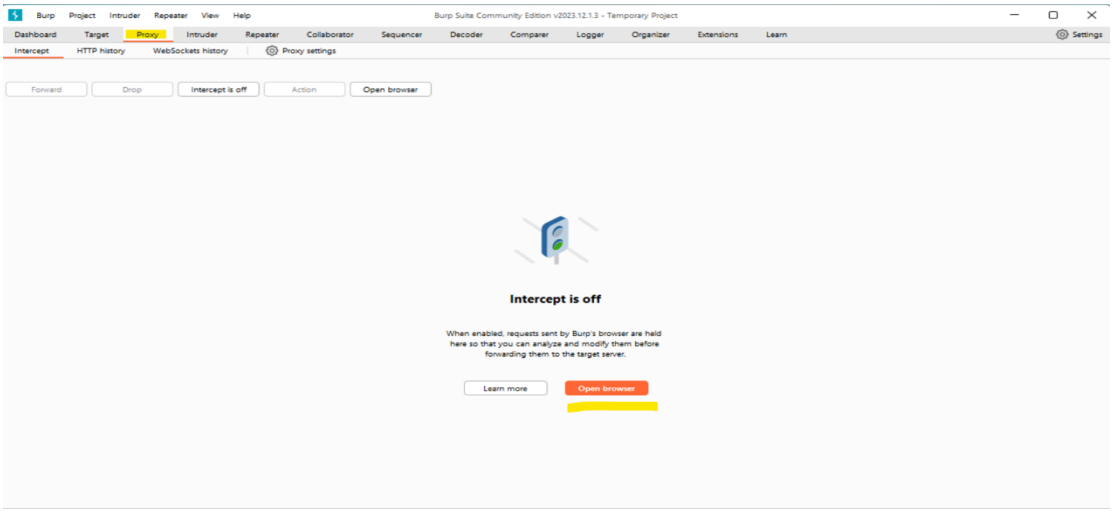


**Figure 21 Project Methodology Design**

**1-Using the Burp Suite application, we open the browser and navigate to the target website.**

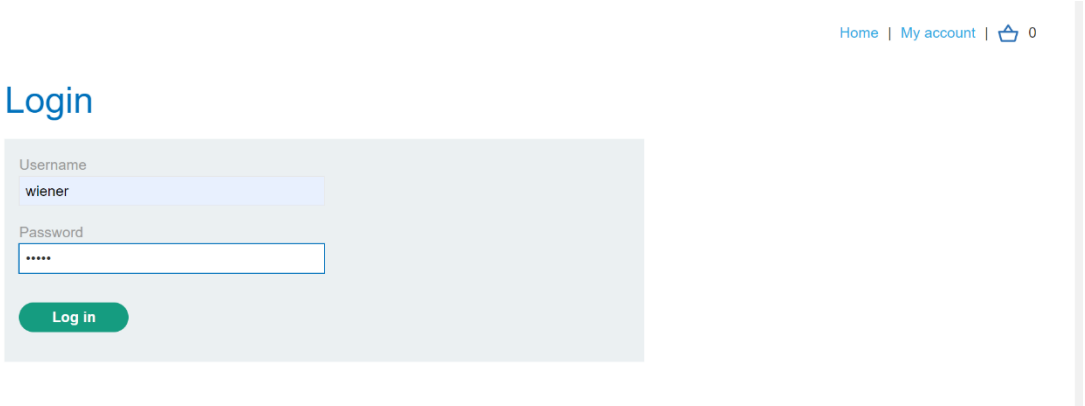


**Figure 22 Project Methodology Design**

**2-We log in to the website.**

Figure 23 Project Methodology Design

## 3-We observe that the available purchase amount is $100.

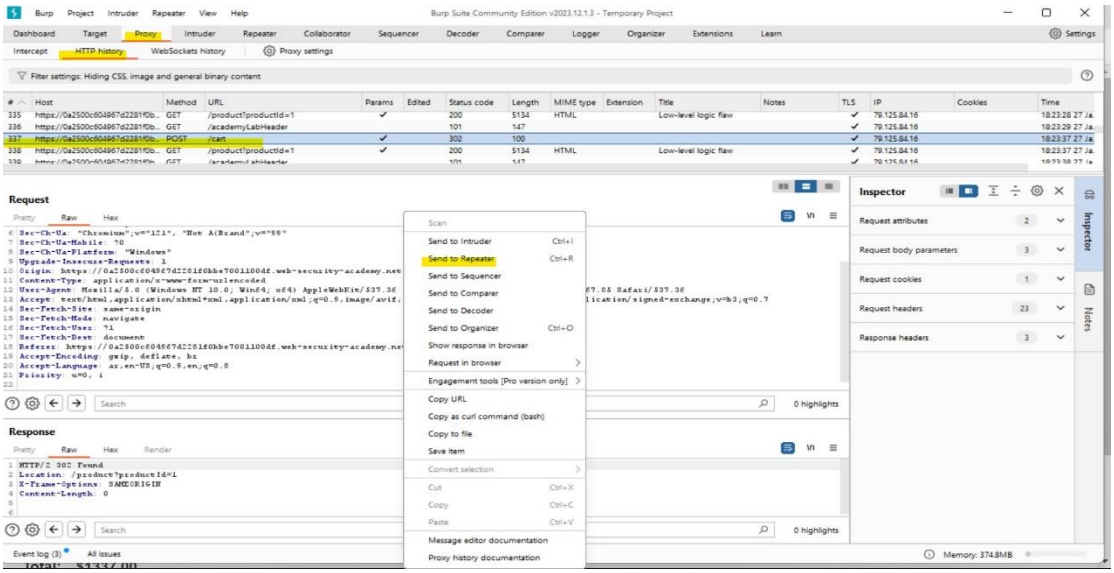

Figure 24 Project Methodology Design

## 4-We navigate to the "Proxy" tab in Burp Suite and select the "HTTP history" sub-tab. From there, we locate and choose the shopping cart page. Afterward, we proceed to send the request to the Repeater.

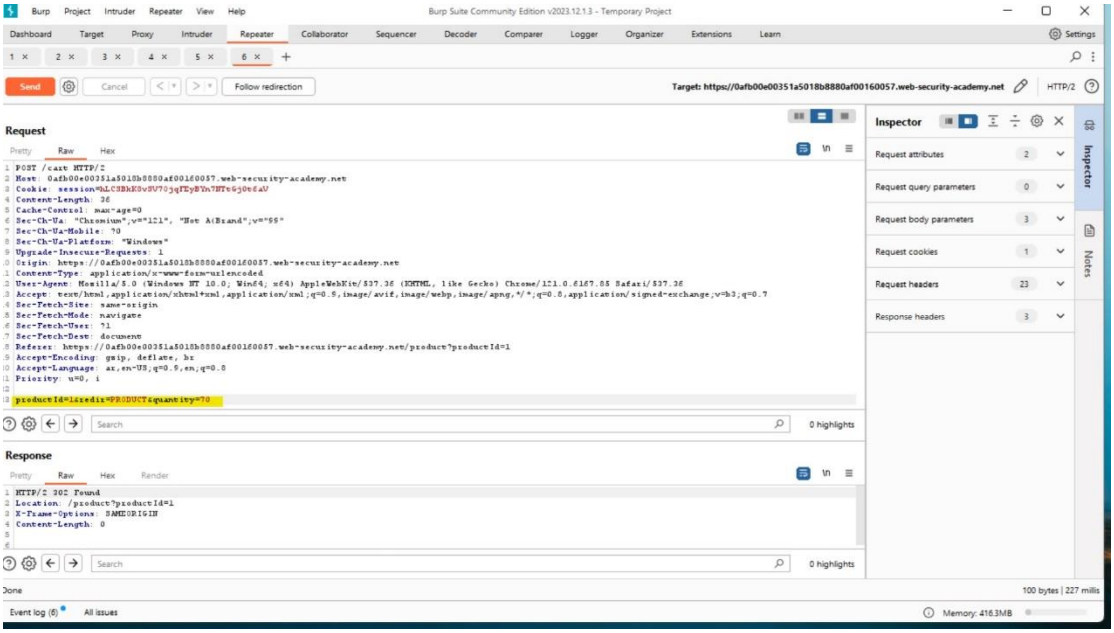

Figure 25 Project Methodology Design

**5-From the Repeater tool, we modify the code to change the quantity to 70. Then, we send the modified request and check if there is a response or not.**

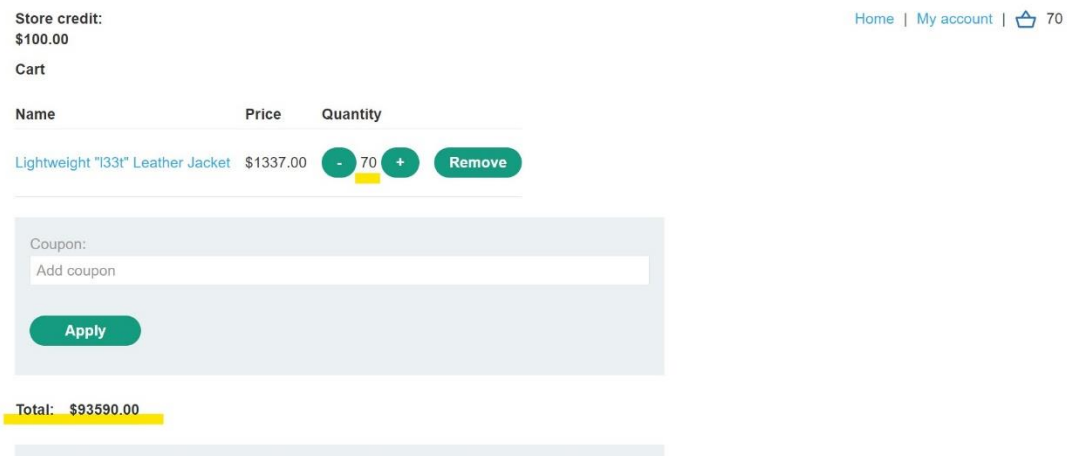


Figure 26 Project Methodology Design

**6-After refreshing the page, we observe that the quantity has been updated to 70. In the next steps, we will proceed with the attack.**

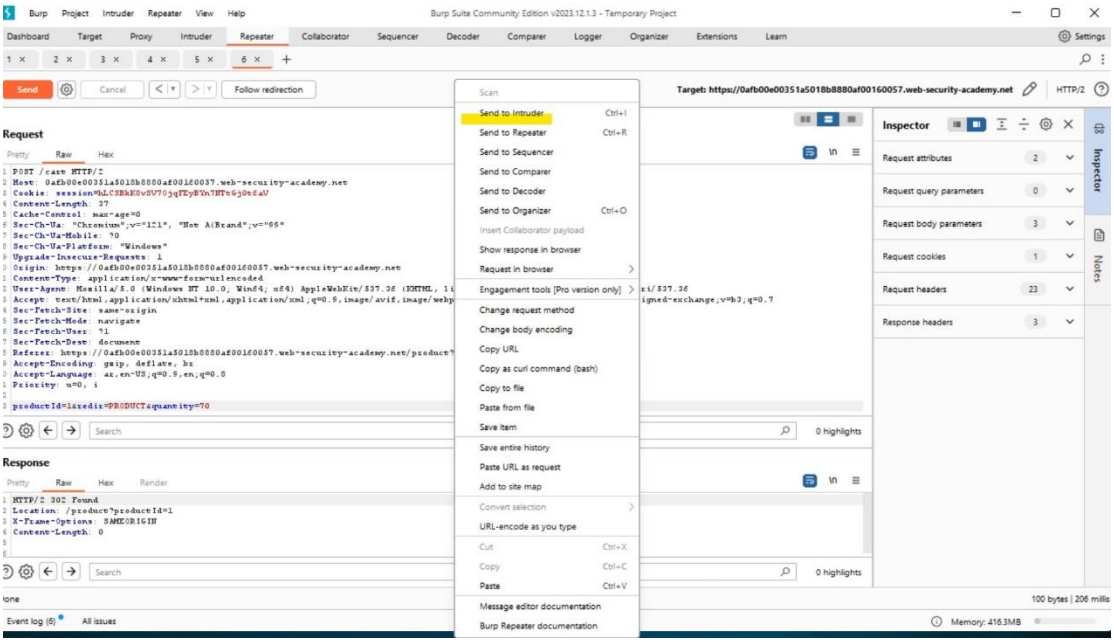


Figure 27 Project Methodology Design

**7-From the Repeater tab in Burp Suite, we right-click and select "Send to Intruder".**

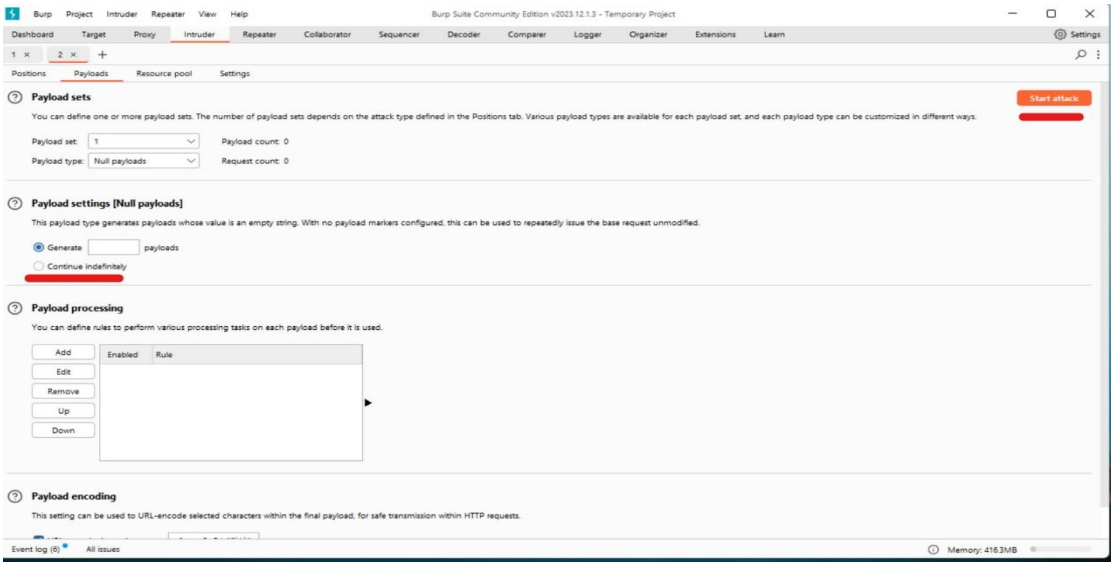


**Figure 28 Project Methodology Design**

**8-From the Intruder tab, we initiate a non-terminated request and start the attack. The goal is to reach a negative value, as there is a vulnerability present in this scenario.**

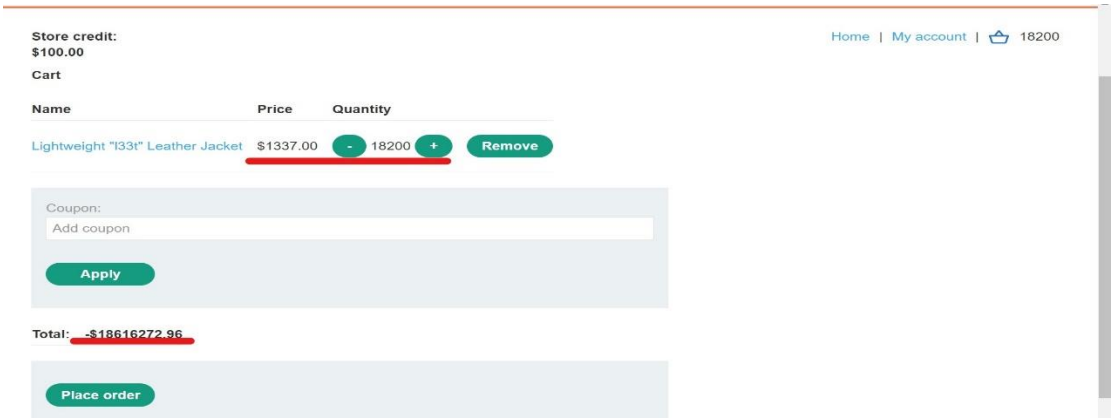


**Figure 29 Project Methodology Design**

**9-After refreshing the page multiple times, the value has become negative.**

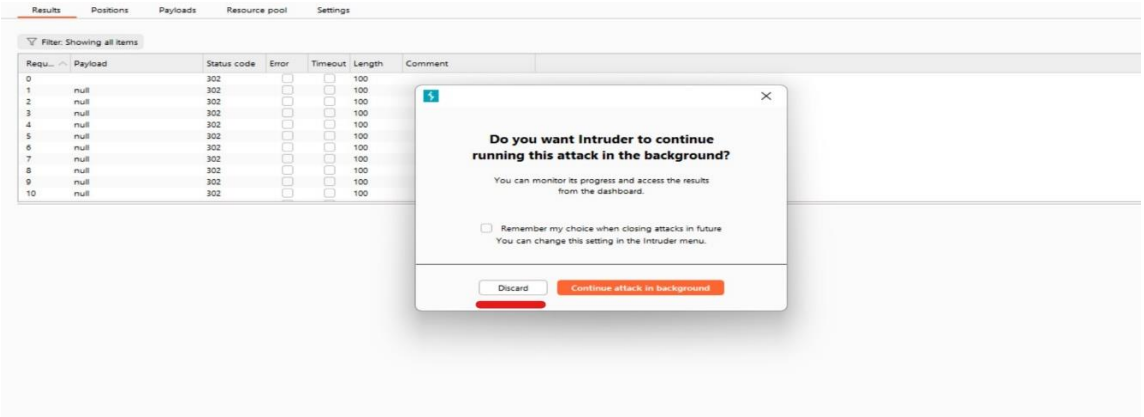


**Figure 30 Project Methodology Design**

## 10-Now we stop the attack after reaching the goal.

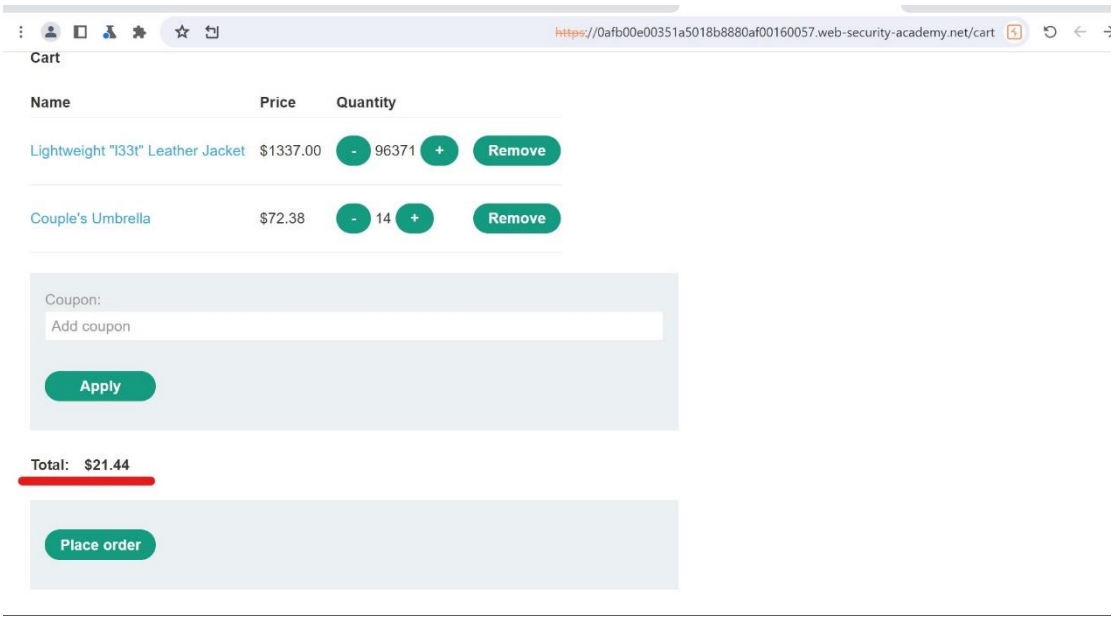


**Figure 31 Project Methodology Design**

## 11-We add another product and start adjusting the value until we reach the desired amount either directly through the website, by sending requests, or through an attack.

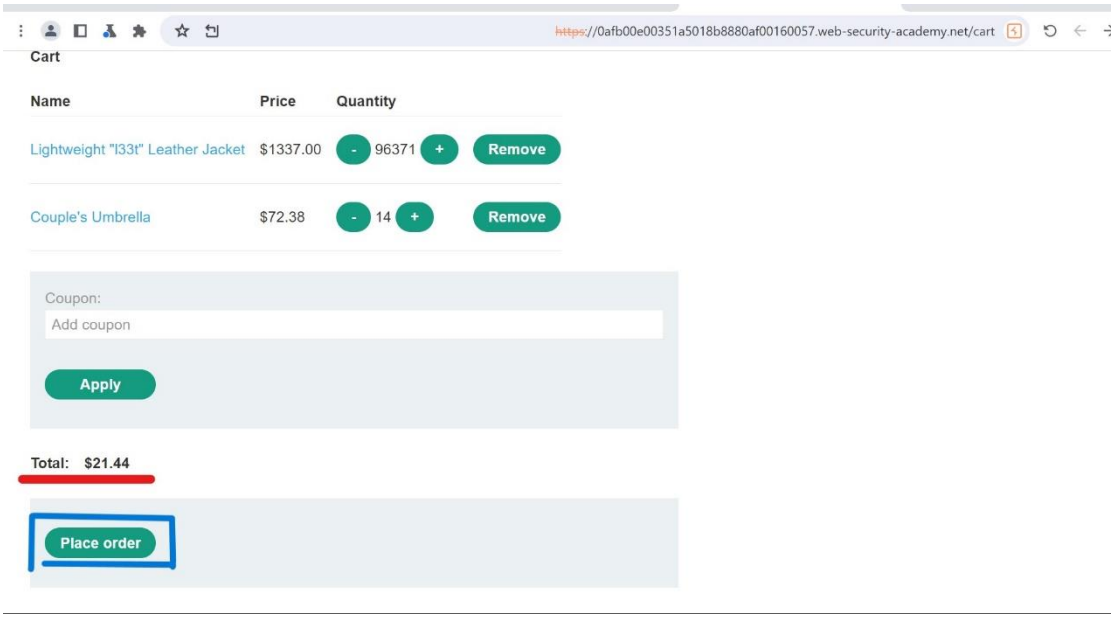


**Figure 32 Project Methodology Design**

## 12-Now we click on "Place order".

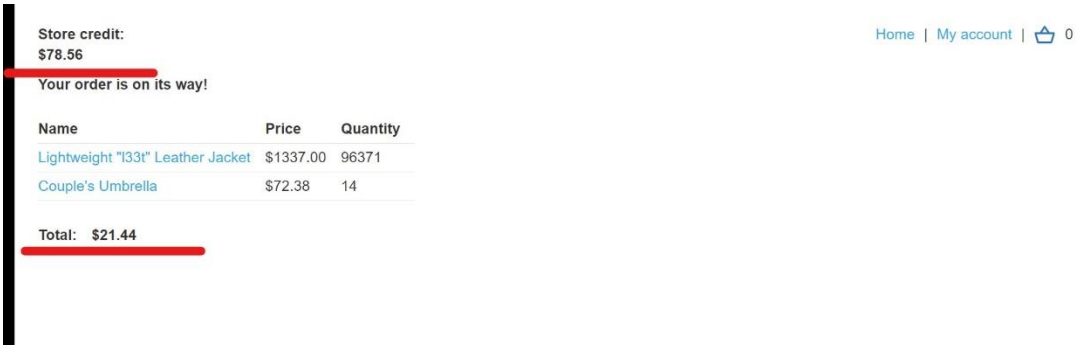


**Figure 33 Project Methodology Design**

## 13-The attack was successfully carried out by exploiting a business logic vulnerability.

## Testing:

**We will present the experience of the operations and mention the extent of the success of each operation.**

| TESTING TYPE | STATUS |
|---|---|
| Manually ensure that SQL injection is protected using the quote mark ['']. | PASS |
| Use the sqlmap tool to extract database names. | PASS |
| Put script code to reflected in page. | PASS |
| Put script code in comment to save in Database. | PASS |
| Upload php file in avatar to execute to get info form server. | PASS |
| Change Original url to Bypass 2FA | PASS |
| Modifying the requests, sending it and receiving responses | PASS |
| Send an attack and reach the desired target | PASS |

## Maintenance:

**The penetration testing process was conducted on the company's website without any technical or administrative problems or obstacles that we encountered.**

**We also conducted an awareness training course for the company's employees that covers basic security aspects and explains the necessary steps for proper behavior in the event of security threats.**

\

## Conclusion:

**In conclusion, we thank God and thank Him for everything. The penetration testing performed on our web application project was a vital step in ensuring the security and integrity of our system. Through rigorous testing and analysis, we have gained valuable insights into potential vulnerabilities and risks that may threaten the confidentiality, availability, and integrity of our applications and data.**

**The penetration testing process allowed us to simulate real-life attacks and identify vulnerabilities that could be exploited by malicious actors. By proactively identifying and remediating these vulnerabilities, we can implement the necessary security measures to strengthen our defenses and protect against potential threats, and the penetration testing results provide us with actionable recommendations to strengthen the security of our web application. These recommendations may include improving authentication mechanisms, implementing secure coding practices, updating software and frameworks, and strengthening access controls. By implementing these measures, we can reduce the risk of unauthorized access, data breaches, and other security incidents.**

**Furthermore, penetration testing emphasized the importance of continuous security testing and monitoring. As technologies evolve and new threats emerge, it is necessary to regularly evaluate the security posture of our web application to identify and address any newly discovered vulnerabilities. By incorporating security testing into our regular practices, we can maintain a proactive security posture and ensure ongoing protection of our application and its data.**

**I would like to express my gratitude to everyone involved in the penetration testing project for their hard work, professionalism, and commitment to securing our web application. Together we have taken important steps towards strengthening the security of our system and ensuring the trust of our users, and we thank everyone for their knowledge.**

## References

**[1] Yadav, S. and Singh, P., 2020. Web Application and Penetration Testing. Journal of Informatics Electrical and Electronics Engineering (JIEEE), 1(2), pp.1-11.**

**[2] Al Shebli, Hessa Mohammed Zaher, and Babak D. Beheshti. "A study on penetration testing process and tools." In 2018 IEEE Long Island Systems, Applications and Technology Conference (LISAT), pp. 1-7. IEEE, 2018.**

**[3] Engebretson, P., 2013. The basics of hacking and penetration testing: ethical hacking and penetration testing made easy. Elsevier.**

**[4] Babar, M.A., Brown, A.W. and Mistrík, I. eds., 2013. Agile software architecture: Aligning agile processes and software architectures. Newnes.**

**[5.] MDPI and ACS Style Altulaihan, E.A.; Alismail, A.; Frikha, M. A Survey on Web Application Penetration Testing. *Electronics* 2023, *12*, 1229.**

**[6] S. Kumar, R. Mahajan, N. Kumar, et al, "A study on web application security and detecting security vulnerabilities," in 6th International Conference on Reliability, Infocom Technologies and Optimization (Trends and Future Directions) (ICRITO) pp. 451-455. Sept. 2017.**

**N. Antunes and M. Vieira, "Enhancing penetration testing with attack signatures and interface monitoring for the detection of injection vulnerabilities in web services," in IEEE International Conference on Services Computing, pp. 104-111, July 2011.**

**[7] P. Vats, M. Mandot and A. Gosain, "A Comprehensive Literature Review of Penetration Testing & Its Applications," *2020 8th International Conference on Reliability, Infocom Technologies and Optimization (Trends and Future Directions) (ICRITO)*, Noida, India, 2020, pp. 674-680, doi: 10.1109/ICRITO48877.2020.9197961.**

**[8]. Schulz, P., 2014. Penetration Testing of Web Applications in a Bug Bounty Program.**

**[9] (https://www.tamkeensecurity.sa)**

**[10] (https://www.sadeed.sa)**

**[11] M. Kumar, "SQL Injection Attack on Database System," Wireless Communication Security, p. 183, 2023.**

**[12] GUPTA, Shashank; GUPTA, Brij Bhooshan. Cross-Site Scripting (XSS) attacks and defense mechanisms: classification and state-of-the-art. International Journal of System Assurance Engineering and Management, 2017, 8: 512**

**[13] Riadi, Imam, and Eddy Irawan Aristianto. "An Analysis of Vulnerability Web Against Attack Unrestricted Image File Upload."** ***Computer Engineering & Applications Journal*** **5.1 (2016).**

**[14] Whitaker, Andrew, and Daniel P. Newman.** ***Penetration Testing and Network Defense: Penetration Testing _1*****. Cisco Press, 2005.**

**[15] Gupta, Shashank, and Brij Bhooshan Gupta. "Cross-Site Scripting (XSS) attacks and defense mechanisms: classification and state-of-the-art."** ***International Journal of System Assurance Engineering and Management*** **8 (2017): 512-530.**

**[16] Holm, Hannes, et al. "A quantitative evaluation of vulnerability scanning."** ***Information Management & Computer Security*** **19.4 (2011): 231-247.**

**[17] Holm, Hannes, et al. "A quantitative evaluation of vulnerability scanning."** ***Information Management & Computer Security*** **19.4 (2011): 231-247.**

**[18] J. Park and R. Sandhu, "Binding Identities and Attributes Using Digitally Signed Certificates," Proc. 16th Ann. Computer Security Applications Conference, IEEE CS Press, Los Alamitos, California, 2000, pp. 120-127**

**[19] Y. Stefinko, A. Piskozub and R. Banakh, "Manual and automated penetration testing. Benefits and drawbacks. Modern tendency,"13th International Conference on Modern Problems of Radio Engineering, Telecommunications and Computer Science (TCSET), Lviv, 2016, pp. 488-491**

**[20] Hassan, M.M., Nipa, S.S., Akter, M., Haque, R., Deepa, F.N., Rahman, M., Siddiqui, M.A. and Sharif, M.H., 2018. Broken authentication and session management vulnerability: a case study of web application.** ***Int. J. Simul. Syst. Sci. Technol, 19*****(2), pp.1-11.**

**[21] https://www.tcc-ict.com/ar**

**[22] https://salam.sa/**

**[23] https://www.cyber.com.sa/**

**[24] https://www.lordgift.in.th/2013/07/client-server-web-app.html**

**[25] Din, Akeel I. Structured query language (SQL) A practical Introduction. 2014.**